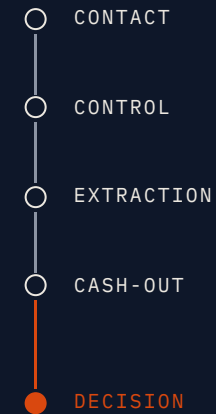


Chakravyuh

Intercept the scam workflow,
not the transaction.

A decision engine for UPI and bank payments that reads each payment session as a four-stage scam workflow — contact, control, extraction, cash-out — and escalates only when that workflow forms, with a reason the customer can read and a signed receipt the bank can audit.



TEAM

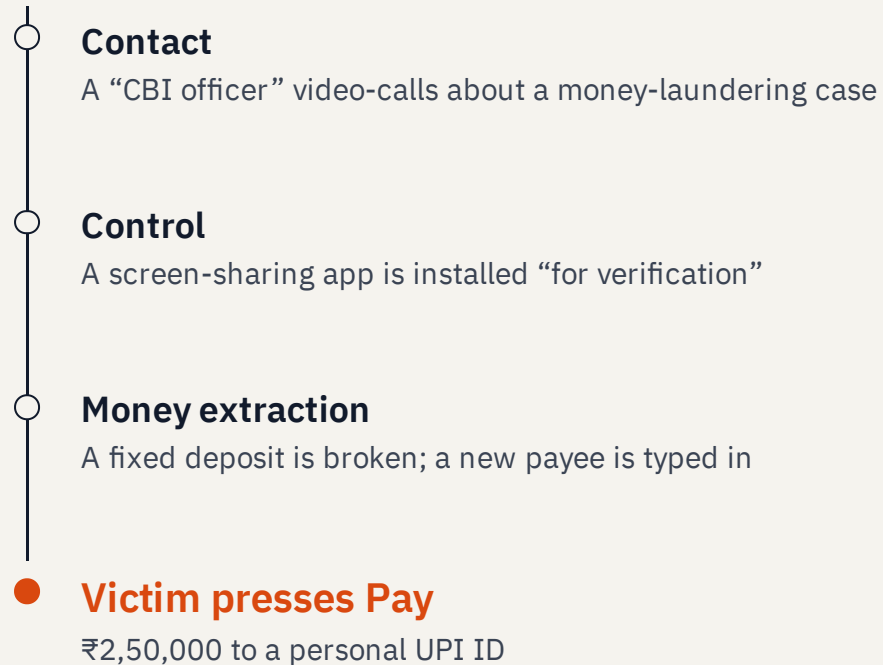
Mathews V Manoj B.Tech Electronics & Communication, Muthoot Institute of Technology and Science (KTU)

All results in this document come from synthetic data.
No real customer, bank or platform data was used.

The victim presses Pay.

In authorised-payment scams the fraud happens *before* the transaction. When the payment is finally made, the PIN is correct, the device is the customer's own and the customer means to pay.

SCAMMER



Invisible to a transaction-only view

The only moment a transaction system scores

₹22,845 cr

lost to cyber fraud in India in 2024

36.37 lakh

complaints filed in 2024

Source: Ministry of Home Affairs, reply in Lok Sabha, July 2025 (NCRP and CFCFRMS data).

Traditional fraud systems often see only the final transaction — and every credential in it is genuine.

Score the workflow, not the transaction.

TRANSACTION VIEW

one payment → suspicious / not suspicious

WORKFLOW VIEW

contact → control → extraction → cash-out → graduated response

→ DECISION

01

Contact

call with an unknown number

call longer than 20 min

scam-lure SMS (classified on-device)

SIGNALS FROM DEVICE

02

Control

screen-sharing app running

app sideloaded in last 24 h

OTP opened during the call

SIGNALS FROM DEVICE

03

Extraction

first-time payee, typed VPA

> 70% of balance

fixed deposit broken in last 24 h

SIGNALS FROM BANK

04

Cash-out

payee behaves like a mule

payee account < 30 days old

payee on a suspect registry

SIGNALS FROM NETWORK

A single signal should not trigger a severe intervention. **The workflow must form.**

A legitimate payment can look odd in isolation — a new payee on rent day, a long call with a plumber. A scam becomes visible through its sequence. Full catalogue of 20 signals: Appendix A.

Escalate only as the workflow forms.

Friction grows with evidence. The bank sets an alert budget for each tier; thresholds are calibrated to it on held-out data.

TIER 1

Observe

TRIGGER

Fused score above τ_1

CUSTOMER SEES

Nothing. The session is logged to the bank's fraud queue.

20.4 legit sessions per 1,000
measured, synthetic · budget 20

TIER 2

Explain + verify

TRIGGER

Score above τ_2 **and** ≥ 2 stages active

CUSTOMER SEES

A warning naming the specific scam pattern, and two questions. The customer can still pay.

2.77 legit sessions per 1,000
measured, synthetic · budget 3

TIER 3

Cool off + human review

TRIGGER

Score above τ_3 **and** ≥ 3 stages, or 2 stages + registry hit

CUSTOMER SEES

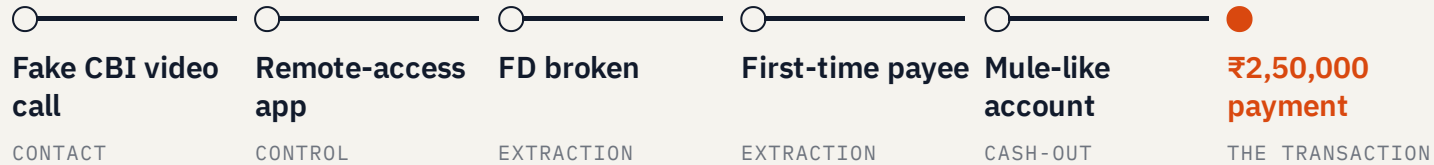
A 30-minute hold before the PIN screen. A bank agent reviews; release needs two approvers.

0.07 legit sessions per 1,000
measured, synthetic · budget 0.5

No tier blocks a customer permanently. Every hold is time-boxed and released or confirmed by a person.

Mrs R., 68. Five warning signs before one payment.

ILLUSTRATIVE COMPOSITE SCENARIO



WITHOUT CHAKRAVYUH

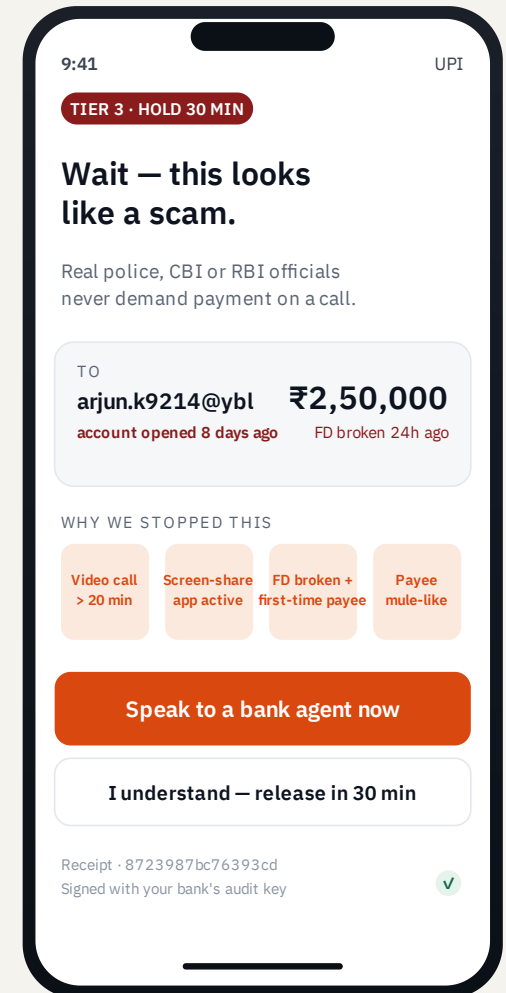
The payment proceeds.

A “new payee + high amount” rule shows a generic warning. She reads it aloud to the caller and confirms. The money reaches a mule account.

WITH CHAKRAVYUH

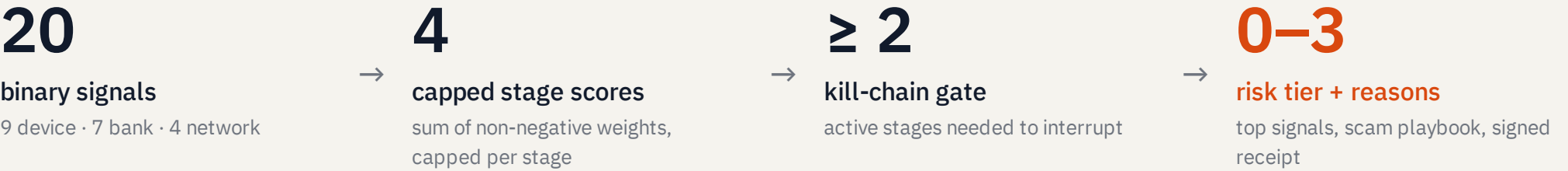
Held before the PIN screen.

All four stages are active → Tier 3 → 30-minute hold → bank agent review. The screen names the pattern: real officials never ask for money on a call.



Tier-3 screen (illustrative mock-up)

Four stages. One decision.



SCORE

$$s(x) = b + \sum_g \min(C_g, \sum_{k \text{ in } g} w_k x_k)$$

DECISION

Tier 2 if $s \geq \tau_2$ and active stages ≥ 2

Tier 3 if $s \geq \tau_3$ and (active stages ≥ 3 or ≥ 2 plus a registry hit)

g runs over the four stages; x_k is 0 or 1; weights $w_k \geq 0$ from L2-regularised logistic regression on labelled sessions, clipped at zero. A stage is active when its capped score ≥ 1.5 . Weights, caps and thresholds: Appendix A.

Non-negative weights	A missing signal never adds or removes suspicion — attackers can always hide one.
Stage caps	No single stage can carry a decision on its own ($C = 5, 5, 6, 6$).
Cross-stage gate	An interruption needs evidence from at least two stages of the workflow.
Prevalence adjustment	Intercept shifted from 3.8% scams in training to an assumed 1 in 5,000 in deployment.
Calibrated thresholds	τ set on a separate validation world to the bank's alert budget, then frozen.

What we measured — on synthetic data.

SYNTHETIC EVALUATION · 8 INDEPENDENT UNSEEN WORLDS · NOT REAL-BANK VALIDATION

92.3%

Tier ≥ 2 recall on 8 unseen synthetic worlds

95% CI [91.7%, 93.0%]

2.77 / 1k

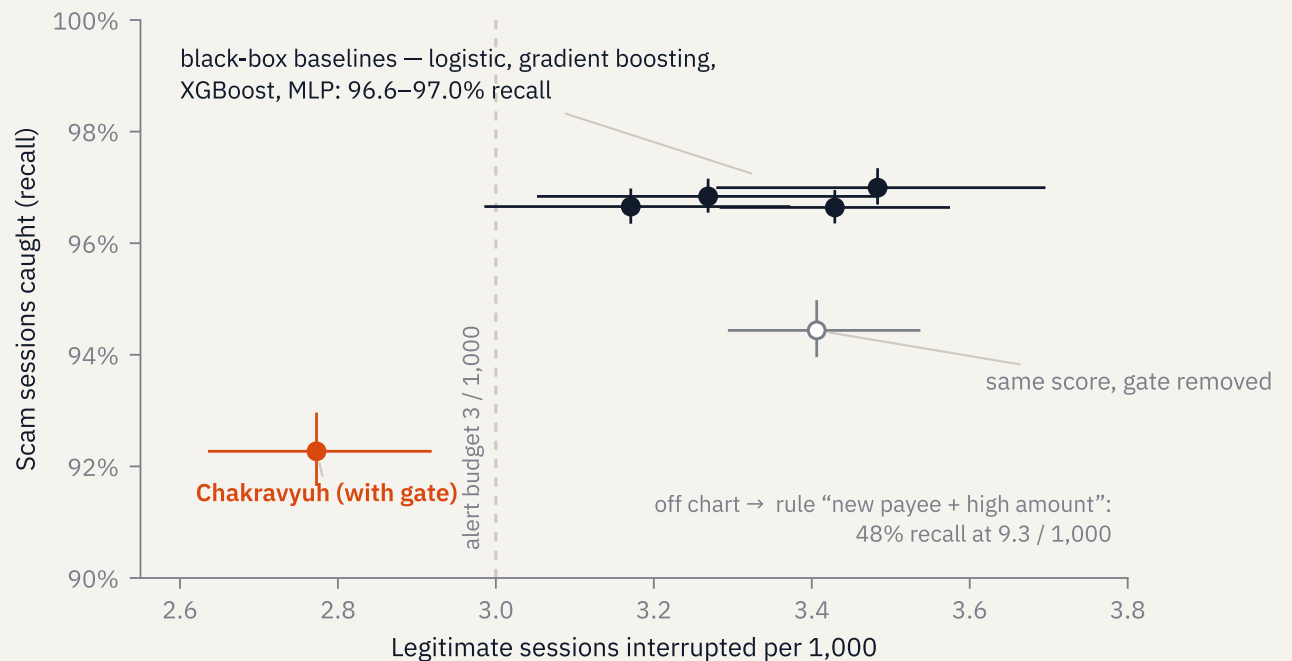
legitimate sessions interrupted — same evaluation

95% CI [2.64, 2.92] · budget 3.0

0.980

AUPRC of the fused score

95% CI [0.978, 0.982]



Same training, calibration and test worlds for every system. Bars: 95% bootstrap CI over the 8 worlds.

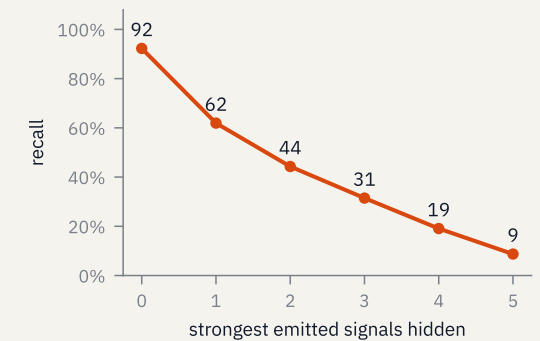
The trade-off, stated plainly. Black-box classifiers reach 96.6–97.0% recall at 3.2–3.5 interruptions per 1,000. Our own score with the gate removed reaches 94.4% at 3.41. The kill-chain gate gives up 2.2 points of recall for 19% fewer interruptions, a guarantee that no single signal can interrupt a payment, and a reason that decomposes into named signals.

Train: world 7 · thresholds: world 21 · test: worlds 101–108
· each world 60,000 legitimate + 2,400 scam sessions. Engine time 23 μ s per session (in-process, measured).

What survives when the attacker adapts?

CAN THE ATTACKER...	DEFENCE	EVIDENCE	
01 ... hide the signals they control? Hang up before paying, avoid screen-share, lower the amount.	Independent stages. Extraction and cash-out evidence is observed by the bank, not the caller.	86.9% recall on the adapted cohort (25% of scam sessions). Worst case — hiding the strongest emitted signal, even ones a fraudster cannot really hide: 62%; two: 44%.	MEASURED
02 ... split one payment into several? Four payments of ₹25,000 instead of one of ₹1,00,000.	“Staircase” signal: two or more payments to new payees within 60 minutes.	Not separately simulated in Round 1.	DESIGN
03 ... pay into older, rented mule accounts? Aged accounts hide the ‘young account’ signal.	Mule score uses fan-in, first-time-sender share and pass-through — not age alone. Other stages still fire.	Mule score flags only 24% of aged mules; sessions paying them are still caught at 73.6%.	MEASURED
04 ... poison the training data? Flood the system with false ‘scam’ or ‘genuine’ reports.	Retrain only on bank-confirmed outcomes; customer reports never become labels on their own.	Not evaluated.	DESIGN

RECALL AS THE ATTACKER HIDES MORE



Attacker knows the published weights and removes the highest-weight signals present in each scam session. Thresholds are not re-tuned.

UNSEEN SCAM PLAYBOOK

Trained without one playbook, tested on it: 79–93% recall.

NO STAGE IS DECORATIVE

Removing contact, control, extraction or cash-out evidence leaves 87%, 92%, 67%, 65% recall.

What never leaves the phone.

NEVER LEAVES THE DEVICE

- ✗ Call audio
- ✗ Screen frames
- ✗ Message text
- ✗ Contact list
- ✗ OTP values
- ✗ App inventory

DEVICE BOUNDARY

LEAVES THE DEVICE

9 derived booleans + amount + hashed payee VPA

1. You are on a call with a number not in your contacts while paying
2. That call has lasted more than 20 minutes
3. A video/VoIP call is active (common in 'digital arrest' scams)
4. A message received in the last 24h matches a known scam lure (KYC, parcel, electricity)
5. A screen-sharing / remote-control app is running
6. An app was installed from outside the Play Store in the last 24h
7. A non-system app can read your screen and draw over the payment app
8. An OTP was opened while the unknown call was active
9. Payee was typed or pasted instead of scanned or picked from contacts

ALREADY INSIDE THE BANK

7 bank-side signals computed on data the bank already holds — first-time payee, amount against the customer's history, balance drain, fixed-deposit break, recent small credits.

4 network signals looked up in the bank's own feature store — mule score, account age, suspect-registry hit, collect request.

$9 + 7 + 4 = 20$ signals.

SIGNED DECISION RECEIPT

```
{ log_id, ts, session, amount, evidence (true only), score, tier, playbook, active_stages,
  action } + HMAC-SHA256
```

One identifier ties the customer's screen, the agent desk and any complaint to the exact evidence and weights. **Implemented:** the server accepts only the 20 catalogued keys and rejects replayed nonces and evidence older than 15 seconds.

Designed with the DPDP Act 2023 principles of purpose limitation and data minimisation. This is a design alignment, not a legal certification. The on-device SDK is proposed; the server contract is implemented.

Workflow context is the difference.

	TRANSACTION CONTEXT	WORKFLOW CONTEXT	EXPLAINABLE REASON	GRADUATED RESPONSE
Transaction rules	✓	—	✓	—
Black-box ML classifier	✓	only if engineered	post-hoc only	—
Chakravyuh	✓	✓	✓	✓

Chakravyuh treats the surrounding scam workflow as first-class evidence.

WHY NOT A GENERIC CLASSIFIER?

On the same synthetic worlds a black box catches about 4 points more scams (slide 7), but it cannot say which stage fired, and nothing stops one strong signal from interrupting a genuine payment. A customer, an agent and an ombudsman all need the reason.

WHAT WE WILL PROVE IN THE 48-HOUR FINALE

H+0-8

Replay harness

Synthetic sessions through /decide with signed receipts and replay checks.

H+8-20

Android signal validation

Measure the 9 device signals on a real handset against ground truth.

H+20-32

Attacker adaptation

Red-team three playbooks against published weights; retrain; compare.

H+32-44

End-to-end replay

100 sessions → tiers → agent-desk review → release or report.

H+44-48

Security + audit walkthrough

Receipts, replay rejection, dual-approver release, limitations.

Built for Round 1: decision engine, threshold calibration, signed receipts with replay checks, synthetic generator and evaluation, 8 automated tests. **Not yet built:** Android SDK, payment-rail hold, agent desk.

System architecture

Four planes. Solid outlines are implemented in Round 1; dashed are simulated with synthetic data; dotted are proposed.

DEVICE · bank app SDK

Signal probes

SIMULATED

Call state, accessibility, installer, on-device SMS classifier. Synthetic in Round 1.

Evidence composer

PROPOSED

9 booleans + amount + payee hash + nonce + timestamp + Play Integrity token.

Tier 1–3 screens

SIMULATED

Playbook message, two questions, hold screen. Mock-ups + web demo.

1 evidence ↓ 5 tier, message and receipt id ↑

BANK FRAUD-OPS VPC

/decide engine

IMPLEMENTED

FastAPI. Stage scores, gate, tier, playbook, top reasons. Stateless.

Replay + schema guard

IMPLEMENTED

Nonce, 15 s freshness, only the 20 catalogued keys accepted.

Signed receipt log

IMPLEMENTED

HMAC-SHA256 over every decision. Key in a KMS is proposed.

Agent desk

PROPOSED

Tier-3 queue, reasons, dual-approver release.

2 payee features ↑ 3 score inside /decide 4 tier-3 hold → rail 6 confirmed outcomes ↓

BANK DATA PLATFORM

Mule-score features

SIMULATED

Fan-in, first-time-sender share, pass-through, age. Synthetic 7-day graph.

Suspect-registry lookup

SIMULATED

Flag only; never shown to customers. Synthetic flag in Round 1.

Weekly retrain

PROPOSED

Bank-confirmed labels only; shadow-mode before rollout.

PAYMENT RAIL / REPORTING

Payment hold

PROPOSED

Time-boxed hold for Tier 3 via the bank's payment switch.

Reporting path

PROPOSED

Agent files to I4C CFCFRMS / 1930 when a scam is confirmed.

implemented simulated proposed No Amazon, NPCI, I4C or bank integration exists today; every proposed item is marked as such.

One payment, traced – and what protects each step

- 1

Pay pressed

SDK composes evidence: only true booleans, amount, payee hash, nonce, timestamp.
- 2

Guard

/decide rejects unknown keys, replayed nonces and evidence older than 15 s.
- 3

Score

Payee features joined from the feature store; stage scores, gate, tier, playbook, top-5 reasons.
- 4

Act

Tier 0 allow · Tier 1 log · Tier 2 warn + two questions · Tier 3 hold before the PIN screen.
- 5

Review

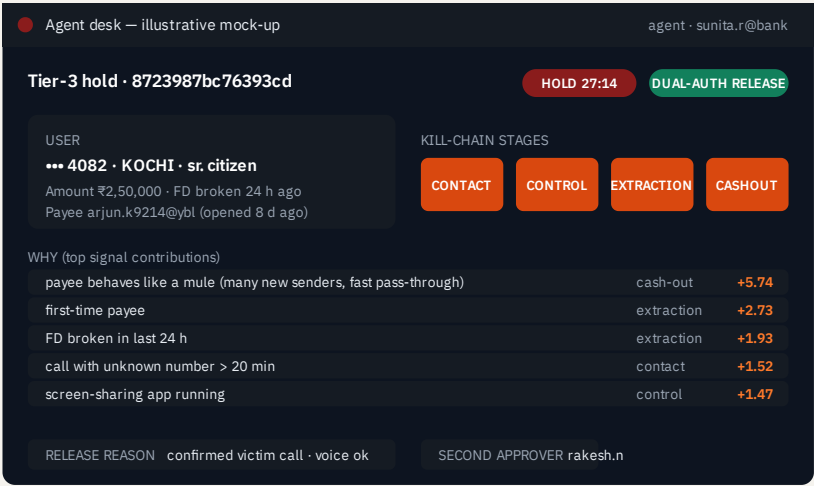
Tier 3 reaches a bank agent with the receipt and reasons. Release needs two approvers.
- 6

Close

Released, or confirmed and reported. The outcome becomes a bank-confirmed label.

SECURITY CONTROLS

THREAT	CONTROL	
Replayed or stale evidence	Nonce + 15 s freshness window at /decide	IMPLEMENTED
Injected or unknown fields	Only the 20 catalogued keys are accepted	IMPLEMENTED
Tampered decision record	HMAC-SHA256 receipt per decision	IMPLEMENTED
Modified or fake app	Play Integrity token bound to a hash of the evidence	PROPOSED
Insider releasing holds	Two approvers; approver ids written into the receipt	PROPOSED
Receipt-store breach	Receipts hold no raw content; identity kept separately	DESIGN
Label poisoning	Retrain on bank-confirmed outcomes only	DESIGN



Escalation and evidence path: customer screen → receipt id → agent desk → release or report. The same receipt id is what a customer quotes in a complaint, so a hold is never an unexplained outcome.

Rollout, performance and modelled economics

ROLLOUT — GATED BY MEASUREMENT

Weeks 0–6 • Shadow	Receipts only, no customer impact. Measure interruptions on real traffic; recalibrate τ to the bank's budget.
Weeks 6–10 • Tiers 1–2	Opted-in segment and high-value person-to-person payments. Proceed only if interruptions $\leq$ budget.
Week 10+ • Tier 3	Payment hold with agent desk and two-approver release.

PERFORMANCE

23 μ s per session for scoring, measured in-process on the evaluation machine. **< 40 ms** end-to-end SDK round trip is a design target, not a measurement.

VALIDATION IN A PILOT

Real-traffic interruption rate, confirmed-scam recall from bank case outcomes, complaint rate and agent review time — reported weekly against the synthetic baseline in this document.

MODELLED / ASSUMPTION — NOT OBSERVED RESULTS

VALUE: AN UPPER BOUND

national reported loss, 2024 (MHA)	₹22,845 cr
× share borne by one pilot bank's customers (assumed)	2%
× Tier $\geq$ 2 recall (synthetic)	92.3%
= upper-bound value intercepted per year	₹422 cr

Upper bound: assumes every Tier $\geq$ 2 detection prevents the full loss. Tier-2 customers may still pay, so real prevention will be lower. Scenario projection — not observed loss prevention.

COST AT 30 M USERS × 250 SESSIONS / YEAR

engine compute (6 instances, peak $\approx$ 2,378 req/s)	₹4.2 lakh / yr
signed receipts (2.6 TB / yr)	₹0.6 lakh / yr
false Tier-3 holds to review (measured rate × volume)	$\approx$ 1,370 / day
agent time at 5 min per review	$\approx$ 114 h / day

Assumptions: peak = 10× average load, 1,000 req/s per instance, doubled for availability, ₹8 per instance-hour, 350-byte receipt, ₹2 per GB-month. Compute is cheap; **human review is the real operating cost**, which is why the Tier-3 budget is set separately. Excludes engineering and SDK work.

Appendix A — signal catalogue and model specification

SIGNAL	STAGE	SOURCE	WEIGHT	MEANING (SHOWN TO USERS AND AGENTS)
bait_credit_7d	contact	bank	+3.00	Small 'profit' credits from unknown senders in the last 7 days
call_long	contact	device	+1.52	That call has lasted more than 20 minutes
sms_scam_flag	contact	device	+1.50	A message received in the last 24h matches a known scam lure (KYC, parcel, electricity)
call_unknown_active	contact	device	+1.13	You are on a call with a number not in your contacts while paying
video_call	contact	device	+0.55	A video/VoIP call is active (common in 'digital arrest' scams)
sideload_24h	control	device	+2.32	An app was installed from outside the Play Store in the last 24h
remote_access	control	device	+1.47	A screen-sharing / remote-control app is running
accessibility_overlay	control	device	+1.34	A non-system app can read your screen and draw over the payment app
otp_read_in_call	control	device	+1.31	An OTP was opened while the unknown call was active
collect_from_p2p	extraction	network	+4.66	This is a 'collect' request from an individual (entering PIN SENDS money)
first_time_payee	extraction	bank	+2.73	You have never paid this account before
balance_drain	extraction	bank	+2.41	This payment empties more than 70% of your balance
vpa_typed	extraction	device	+2.08	Payee was typed or pasted instead of scanned or picked from contacts
fd_broken_24h	extraction	bank	+1.93	A fixed deposit was broken / loan taken in the last 24h
amount_high	extraction	bank	+1.71	Amount is far above your usual payments
staircase	extraction	bank	+1.19	Several payments to new accounts in the last 60 minutes
amount_very_high	extraction	bank	+0.51	Amount is extremely high for you (top 0.1% of your history)
payee_mule_high	cash-out	network	+5.74	The receiving account behaves like a mule account (many unrelated senders, money moved out fast)
payee_registry_hit	cash-out	network	+3.43	The receiving account is on the I4C / bank suspect registry
payee_new_account	cash-out	network	+1.00	The receiving account was opened less than 30 days ago

MODEL

$$s(x) = b + \sum_g \min(C_g, \sum_{k \in g} w_k x_k)$$

Weights: logistic regression, L2, $C = 0.3$, fitted on world 7 (60,000 legitimate + 2,400 scam sessions), clipped at 0. Absent signals contribute nothing.

Intercept b shifted from training prevalence (3.85%) to an assumed deployment prevalence of 1 in 5,000.

Caps C : contact 5, control 5, extraction 6, cash-out 6. Stage active when capped score ≥ 1.5 .

Thresholds (log-odds), calibrated on world 21 to 20 / 3 / 0.5 legitimate alerts per 1,000: $\tau_1 = -9.11$, $\tau_2 = -8.34$, $\tau_3 = -7.63$.

Playbook label (digital arrest, remote-access KYC, investment/task, collect request) chosen by overlap with each playbook's signal fingerprint; it selects the customer message, not the tier.

Source split: 9 device, 7 bank, 4 network = 20. Weights are published here deliberately; slide 8 measures what an attacker who reads them can achieve.

Appendix B — evaluation methodology and full results

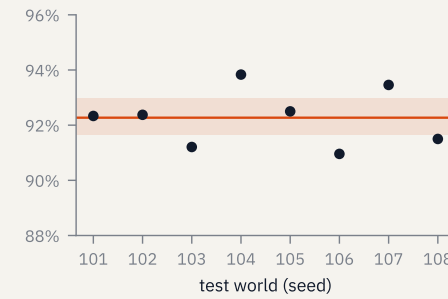
Data. A seeded generator (chakravyuh/synth.py) produces legitimate sessions with realistic confounders (paying a plumber during his call, rent day, ignored scam SMS) and four scam playbooks. 25% of scam sessions are “adapted”: call, video and screen-share signals hidden and amounts lowered. Payees come from a synthetic 7-day payment graph with 120 mules (25% aged 120+ days). No real data is used anywhere.

Protocol. Train on world 7; calibrate thresholds on world 21; test on worlds 101–108, each 60,000 legitimate + 2,400 scam sessions. Every system uses the same worlds and a 3 / 1,000 budget. CIs: bootstrap over the 8 worlds.

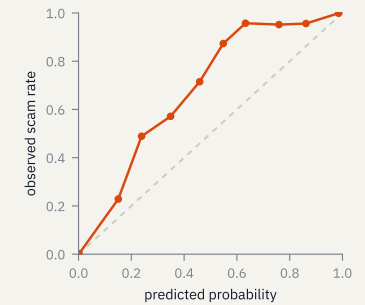
SYSTEM	RECALL [95% CI]	INTERRUPTIONS / 1K	AUPRC
Chakravyuh (tier ≥ 2)	92.3% [91.7%, 93.0%]	2.77 [2.64, 2.92]	0.980
Chakravyuh score, gate removed	94.4% [94.0%, 95.0%]	3.41 [3.29, 3.54]	—
Logistic regression	96.6% [96.4%, 97.0%]	3.43 [3.28, 3.58]	0.984
Gradient boosting	96.7% [96.3%, 97.0%]	3.17 [2.99, 3.37]	0.985
XGBoost	96.8% [96.5%, 97.2%]	3.27 [3.05, 3.48]	0.985
MLP	97.0% [96.7%, 97.3%]	3.48 [3.28, 3.70]	0.985
Rule: new payee + high amount	48.1% [47.6%, 48.6%]	9.34 [9.10, 9.54]	—

The fixed rule cannot be tuned to a budget, so it is reported at its natural operating point.

RECALL PER TEST WORLD



RELIABILITY (PREVALENCE-ADJUSTED)



Calibration. Scores are shifted to the 1-in-5,000 deployment prior; for this check they are shifted back to the test prevalence (3.85%). Brier 0.0040, ECE 0.0024.

Adversary (strongest emitted signals hidden): 0: 92% · 1: 62% · 2: 44% · 3: 31% · 4: 19% · 5: 9%.

Stage ablation (retrained without the stage): none: 92% (2.77/1k) · contact: 87% (2.98/1k) · control: 92% (3.50/1k) · extraction: 67% (3.10/1k) · cashout: 65% (2.37/1k).

Leave one playbook out: digital arrest: 93% · remote access kyc: 89% · investment task: 81% · collect request: 79%. **Per playbook:** digital arrest: 93% · remote access kyc: 97% · investment task: 92% · collect request: 83%.

Per persona (recall / interruptions per 1k): student: 92% / 2.73 · shopkeeper: 92% / 2.64 · senior: 92% / 2.93 · professional: 93% / 2.79.

Stage caps produced no measurable change on these worlds (identical recall and interruptions without caps); they remain as a guarantee against a single extreme stage. Tier-3 recall: 57.9%.

Appendix C — assumptions, design alignment, SDK sketch, sources

ASSUMPTIONS

ITEM	VALUE	USED IN
Deployment prevalence	1 scam per 5,000 sessions	intercept shift only
Alert budgets	20 / 3 / 0.5 per 1,000	bank-chosen, per tier
Adapted cohort	25% of scam sessions	synthetic
Pilot exposure share	2% of national reported loss	value model
Load	30 M users × 250 sessions / yr; peak 10× average	cost model
Unit costs	₹8 / instance-hour; ₹2 / GB-month; 5 min / review	cost model

REGULATORY DESIGN ALIGNMENT — NOT CERTIFICATION

DPDP Act 2023	Purpose limitation, data minimisation: only derived booleans leave the device.
RBI Master Direction on Digital Payment Security Controls (2021)	Fraud-risk monitoring: graduated, explainable interruption with human review.
RBI Integrated Ombudsman Scheme (2021)	The receipt id gives a complaint a single, verifiable reference.
PMLA 2002 record-keeping	Receipts retained for the statutory period, stored apart from identity data.
I4C CFCFRMS / 1930	Proposed reporting path for confirmed scams; no integration exists today.

SOURCES

Ministry of Home Affairs, reply in Lok Sabha, July 2025: ₹22,845.73 crore lost to cyber fraud in 2024; 36.37 lakh complaints (NCRP and CFCFRMS). Digital Personal Data Protection Act, 2023. RBI Master Direction on Digital Payment Security Controls, 2021. RBI Integrated Ombudsman Scheme, 2021. I4C Suspect Registry, launched September 2024.

ANDROID SIGNAL PROBES — SKETCH, NOT YET BUILT

```
class ChakravayuhProbes(ctx: Context, integrity: StandardIntegrityTokenProvider) {
  fun evidence(nonce: String): Evidence {
    val ev = mapOf(
      "call_unknown_active" to isUnknownCallActive(),
      "call_long"           to callDurationSec() >= 20 * 60,
      "video_call"          to voipAudioModeActive(),
      "sms_scam_flag"        to onDeviceLureClassifier.hitWithin(24.hours),
      "remote_access"        to screenShareOrRemoteAppRunning(),
      "sideload_24h"         to installedOutsideStore(within = 24.hours),
      "accessibility_overlay" to thirdPartyOverlayAndA11yEnabled(),
      "otp_read_in_call"     to (isUnknownCallActive() && otpNotificationOpened()),
      "vpa_typed"            to payeeEnteredManually() // 9 device signals
    ).filterValues { it } // send only true ones
    val body = canonicalJson(ev, amount, payeeHash, nonce, now())
    val token = integrity.request(requestHash = sha256(body)) // server verifies
    return Evidence(body, token)
  }
}
```

DISCLOSURES

All data is synthetic. No models are pre-trained; no LLM is used at decision time. Code: Python (FastAPI, scikit-learn, XGBoost, NumPy, NetworkX, Matplotlib). Typeface: IBM Plex (SIL Open Font License). Drafting, code and layout were produced with the help of an AI assistant (Claude Code); every number was computed by the project's evaluation scripts (eval/final_numbers.py) and checked against them. Phone and agent-desk screens are illustrative mock-ups.